



آموزش تست نفوذ و رد تیم TryHackBox



PHISHING EMAIL ANALYSIS

Uncover the Deception, Protect Your Data!





موضوع :

مقدمات فیشینگ ایمیل



تهیه شده توسط تیم TryHackBox

The Chaos



لینک زیر جهت حمایت از جامعه آموزش رایگان :

<https://darametcom/TryHackBox>

ما را به دوستانتان معرفی کنید

دیگر کانال ها و شبکه های اجتماعی ما را دنبال کنید:

کانال های تلگرام ما

آموزش تست نفوذ و Red Team :

[@TryHackBox](https://t.me/TryHackBox)

رودمپ های مختلف:

[@TryHackBoxOfficial](https://t.me/TryHackBoxOfficial)

داستان های هک:

[@TryHackBoxStory](https://t.me/TryHackBoxStory)

آموزش برنامه نویسی:

[@TryCodeBox](https://t.me/TryCodeBox)

رادیو زیروپاد (پادکست ها):

[@RadioZeroPod](https://t.me/RadioZeroPod)

اینستاگرام :

<http://www.instagram.com/TryHackBox>

یوتیوب:

<https://youtube.com/@tryhackbox>





Introduction to Phishing

حمله فیشینگ نوعی حمله با هدف سرقت اطلاعات شخصی کاربر به طور کلی با کلیک بر روی مخرب است به کاربران از طریق ایمیل یا اجرای فایل های مخرب در رایانه آنها پیوند می دهد حملات فیشینگ مربوط به مرحله «تحویل» در مدل زنجیره کشتار سایبری است که برای تجزیه و تحلیل سایبری ایجاد شده است

حملات مرحله تحویل مرحله ای است که در آن مهاجم محتوای مضر از قبل آماده شده را به سیستم ها / افراد قربانی منتقل می کند

Phases of the Intrusion Kill Chain



مراحل زنجیره کشف نفوذ

1. شناسایی و جمع آوری اطلاعات (Reconnaissance)

- تحقیق، شناسایی و انتخاب اهداف توسط مهاجم



2. مسلح سازی (Weaponization)

- جفت کردن بدافزار دسترسی از راه دور با یک حفره امنیتی (اکسپلویت) برای ایجاد یک محموله قابل ارسال مانند فایل های PDF ادوبی یا میکروسافت آفیس

3. تحویل (Delivery)

- انتقال سلاح (محموله مخرب) به هدف از طریق روش هایی مانند پیوست ایمیل، وبسایت ها یا درایوهای USB

4. بهره برداری (Exploitation)

- پس از تحویل، کد مخرب فعال شده و از حفره های امنیتی برنامه ها یا سیستم ها سوءاستفاده می کند

5. نصب (Installation)

- سلاح یک درپشتی (Backdoor) روی سیستم هدف نصب می کند تا دسترسی پایدار برای مهاجم فراهم شود

6. فرمان و کنترل (Command & Control)

- یک سرور خارجی با بدافزار ارتباط برقرار کرده و دسترسی "همانند دسترسی صفحه کلید" را در داخل شبکه هدف فراهم می کند

7. اقدامات برای دستیابی به هدف (Actions on Objective)

- مهاجم برای دستیابی به هدف نفوذ خود اقدام می کند که می تواند شامل سرقت یا تخریب داده ها، یا نفوذ به هدف دیگری باشد



حمله فیشینگ رایج ترین بردار حمله برای دسترسی اولیه است. البته تنها هدف از حمله دزدیدن اطلاعات رمز عبور کاربر نیست. هدف از چنین حملاتی، بهره برداری از عامل انسانی، ضعیف ترین حلقه در زنجیره است. مهاجمان از فیشینگ استفاده می کنند حملات به عنوان اولین گام برای نفوذ به سیستم ها.

تحلیل ایمیل فیشینگ چیست؟

تجزیه و تحلیل ایمیل های فیشینگ شامل مطالعه محتوای ایمیل های فیشینگ برای اطمینان از تکنیک هایی است که مهاجم استفاده می کند.

شاخص رایج ایمیل فیشینگ چیست؟

شاخص های رایج ایمیل های فیشینگ شامل آدرس ها، پیوندها یا نام های دامنه مشکوک، زبان تهدید یا احساس فوریت، اشتباهات در ایمیل، گنجاندن پیوست های مشکوک و ایمیل هایی است که اطلاعات حساس را درخواست می کنند.

Elements of a phishing email

All phishing emails include one of two components: a link or an attachment. Getting victims to click the link or open the attachment requires a sophisticated set of tools and techniques. Below are some of the most important elements of a phishing email:

Subject line

Perhaps the most critical element of a phishing email, the subject line is designed to entice, alarm, or frighten the victim into opening the email. Hackers who have done their research write highly targeted subject lines to entice victims into opening emails.

Email spoofing

Email spoofing involves creating an email address that looks like that of a trusted business. With display name spoofing, the hacker adds the desired display name in the sender field of the email. In other cases, a hacker will use an email address resembling a legitimate business email as the display name.

Brand impersonation

Hackers impersonate the brands you trust the most. When attacking businesses, hackers impersonate brands that a business has a relationship with, such as a bank or a software vendor. To create the illusion of legitimacy, phishers use real business and product logos and other visual elements of the brand's identity.

Phishing link

A link is typically placed in the body of the email, but it can also be placed inside an attachment or inside a legitimate hosted file on a service like OneDrive or SharePoint to avoid detection from email filters scanning for known phishing links. Victims are lured into clicking on the link by the email itself, which directs the user to visit a website to log into an account.

Attachment

Attachments are included either to conceal the phishing link from an email filter or to deliver malware/ransomware. Often in the form of a Word document, PDF, or .zip file, the attachment appears to be legitimate business correspondence, such as an invoice. The link might lead to a phishing website or result in an automatic download of malware or ransomware.

Phishing page

A phishing page is a fraudulent webpage that impersonates a brand. Unsophisticated pages are easy to spot, but advanced phishers use real CSS from brand webpages to make their webpages identical to the real thing. Phishing pages impersonate login pages where victims enter their username and password to access their account. When they do so, their credentials are stolen.



عناصر تشکیل دهنده یک ایمیل فیشینگ

تمامی ایمیل‌های فیشینگ شامل یکی از این دو جزء هستند: یک لینک یا یک پیوست. هادار کردن قربانیان برای کلیک روی لینک یا باز کردن پیوست، به مجموعه‌ای پیچیده از ابزارها و تکنیک‌ها نیاز دارد. در زیر برخی از مهم‌ترین عناصر یک ایمیل فیشینگ آورده شده است:

1. خط موضوع (Subject Line)

شاید این بخش، مهم‌ترین عنصر ایمیل فیشینگ باشد. خط موضوع به گونه‌ای طراحی شده است که قربانی را ترغیب، مضطرب یا بترساند تا ایمیل را باز کند. هک‌هایی که تحقیقات خود را انجام داده‌اند، خطوط موضوع بسیار هدفمندی می‌نویسند تا قربانیان را به باز کردن ایمیل وسوسه کنند.

2. جعل هویت ایمیل (Email Spoofing)

این تکنیک شامل ایجاد یک آدرس ایمیل است که شبیه آدرس یک کسب‌وکار معتبر به نظر می‌رسد. در «جعل نام نمایشی»، هکر نام نمایشی مورد نظر خود را در فیلد فرستنده ایمیل وارد می‌کند. در موارد دیگر، هکر از آدرس ایمیلی استفاده می‌کند که شبیه به آدرس ایمیل قانونی یک کسب‌وکار است.

3. جعل هویت برند (Brand Impersonation)

هکرها برندهایی را که شما بیشتر به آنها اعتماد دارید، جعل می‌کنند. هنگام حمله به کسب‌وکارها، هکرها برندهایی را که کسب‌وکار هدف با آنها رابطه دارد (مانند یک بانک یا فروشنده نرم‌افزار) جعل می‌کنند. برای ایجاد گواهی از مشروعیت، فیشرها از لوگوهای واقعی کسب‌وکارها و محصولات و سایر عناصر بصری هویت برند استفاده می‌کنند.

4. پیوست (Attachment)



پیوست‌ها یا برای پنهان کردن لینک فیشینگ از فیلترهای ایمیل استفاده می‌شوند یا برای تحویل بدافزار/باج‌افزار. این پیوست‌ها که اغلب به صورت سند Word ، PDF یا فایل zip هستند، به عنوان یک مکاتبه قانونی کسب‌وکاری (مانند یک فاکتور) ظاهر می‌شوند. این لینک ممکن است به یک وب‌سایت فیشینگ منتهی شود یا منجر به دانلود خودکار بدافزار یا باج‌افزار گردد.

5. لینک فیشینگ (Phishing Link)

این لینک معمولاً در بدنه ایمیل قرار می‌گیرد، اما می‌تواند در داخل یک پیوست یا داخل یک فایل میزبانی شده قانونی در سرویسی مانند OneDrive یا SharePoint نیز قرار داده شود تا از تشخیص توسط فیلترهای ایمیل که به دنبال لینک‌های فیشینگ شناخته شده هستند، اجتناب شود. قربانیان با ترفندهای موجود در خود ایمیل فریب خورده و روی لینک کلیک می‌کنند. این لینک کاربر را به یک وب‌سایت جعلی هدایت می‌کند تا در حساب خود وارد شود.

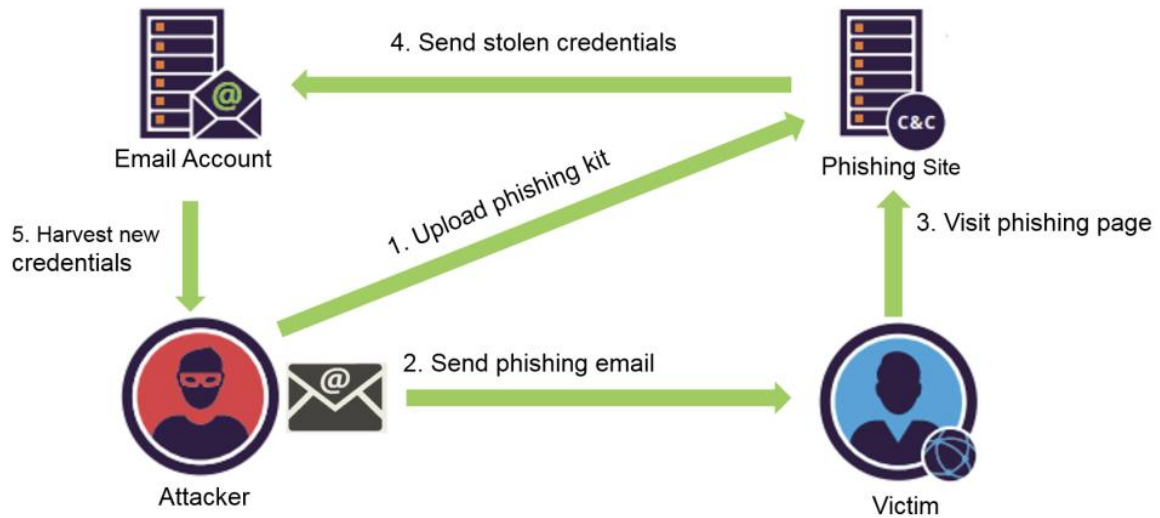
6. صفحه فیشینگ (Phishing Page)

یک صفحه فیشینگ، یک صفحه وب متقلبانه است که یک برند را جعل می‌کند. تشخیص صفحات ساده و غیرپیچیده آسان است، اما فیشرهای حرفه‌ای از CSS واقعی صفحات وب برندها استفاده می‌کنند تا صفحاتشان عین نسخه اصلی به نظر برسد. این صفحات، صفحات ورود به سیستم را جعل می‌کنند و قربانیان نام کاربری و رمز عبور خود را برای دسترسی به حسابشان در آن وارد می‌کنند. وقتی این کار را انجام می‌دهند، اعتبارشان (Credentials) دزدیده می‌شود.

TryHackBox



Phishing attack flow



EXAMPLE OF PHISHING EMAIL

EXAMPLE OF PHISHING EMAIL

Fri 12/11/2015 10:33 AM

Urgency

Critical System Maintenance Team '<noreply@csmt.com>

URGENT: Critical System Maintenance - Validate user account

To: [Redacted]

Follow up. Start by Friday, December 11, 2015. Due by Friday, December 11, 2015. This message was sent with High importance.

Dear user,

We are about to carry out maintenance on our user interface. Upon the receipt of this notice, you are required to validate users can access the interface.

Failure to validate account functions within this time duration, will inactive all user accounts.

To validate the user interface, click on the web-link below or copy the link in your web-browser:

<http://reviewuserinterface.com/verify>

Yours in service,

Critical System Maintenance Team

Annotations:

- Not sent to you.
- Not addressed directly to you.
- Generic reference to unidentified system.
- Contains 'threat' if you don't act on email.
- Attempts to direct you to a link



Information Gathering

جعل (spoofing)

مهاجمان می توانند از طرف شخص دیگری ایمیل ارسال کنند، زیرا ایمیل ها لزوماً مکانیزم احراز هویت ندارند. مهاجمان می توانند با استفاده از تکنیکی به نام جعل، از طرف شخص دیگری نامه ارسال کنند تا کاربر باور کند که ایمیل دریافتی قابل اعتماد است.

چندین پروتکل برای جلوگیری از تکنیک Email Spoofing ایجاد شده است. با کمک پروتکل های SPF، DKIM و DMARC می توان جعلی یا واقعی بودن آدرس فرستنده را فهمید. برخی از برنامه های ایمیل این بررسی ها را به صورت خودکار انجام می دهند. اما استفاده از این پروتکل ها اجباری نیست و در برخی موارد می تواند مشکلاتی را ایجاد کند.

➤ چارچوب خط مشی فرستنده (SPF)

➤ ایمیل شناسایی شده با کلیدهای دامنه (DKIM)

برای اینکه به صورت دستی بفهمید که آیا نامه جعلی است یا خیر، ابتدا باید آدرس SMTP نامه را یاد بگیرید. رکوردهای SPF، DKIM، DMARC و MX دامنه را می توان با استفاده از ابزارهایی مانند Mxtoolbox یاد گرفت. با مقایسه اطلاعات اینجا می توان فهمید که آیا نامه جعلی است یا خیر.

SuperTool Beta7

umuttosun.com

MX Lookup

mx.umuttosun.com Find Problems

Pref	Hostname
0	umuttosun.com

Test

- DMARC Record Published
- DMARC Policy Not Enabled
- DNS Record Published

Results

Result
No DMARC Record found
DMARC Quarantine/Reject policy not enabled
DNS Record found



از آنجایی که آدرس‌های IP مؤسسات بزرگی که از سرورهای پست الکترونیکی خودشان استفاده می‌کنند متعلق به آنهاست، می‌توان با مشاهده رکوردهای whois آدرس SMTP IP بررسی کرد که آیا آدرس SMTP متعلق به آن مؤسسه است یا خیر.

یک نکته مهم در اینجا این است که اگر آدرس فرستنده جعلی نباشد، نمی‌توانیم بگوییم نامه امن است. ایمیل‌های مضر را می‌توان از طرف افراد مورد اعتماد با هک کردن آدرس‌های ایمیل شرکتی / شخصی ارسال کرد. این نوع حملات سایبری قبلاً اتفاق افتاده است، بنابراین این احتمال باید همیشه در نظر گرفته شود.

E-mail Traffic Analysis

تحلیل ترافیک ایمیل

هنگام تحلیل یک حمله فیشینگ، پارامترهای زیادی مورد نیاز است. با جستجو بر اساس پارامترهای زیر در درگاه ایمیل (Mail Gateway) می‌توانیم اندازه حمله و مخاطبان هدف را بیاموزیم.

• آدرس فرستنده

- آدرس IP پروتکل SMTP

- دامنه آدرس ایمیل

- موضوع ایمیل

توجه: آدرس فرستنده و آدرس SMTP ممکن است دائماً در حال تغییر باشند

در نتایج جستجو، علاوه بر تعداد ایمیل‌ها، لازم است اطلاعات آدرس‌های گیرندگان و اطلاعات زمانی نیز آموخته شود.



نکات کلیدی تحلیل:

- اگر ایمیل‌های مخرب به طور مداوم به کاربران یکسانی ارسال شوند، ممکن است آدرس ایمیل آن‌ها به طریقی **نشت کرده** و در سایت‌هایی مانند **PasteBin** به اشتراک گذاشته شده باشد.
- حمله‌کنندگان می‌توانند آدرس‌های ایمیل را با ابزاری مانند **theHarvester** در کالی لینوکس پیدا کنند. توصیه می‌شود چنین اطلاعاتی به طور واضح به اشتراک گذاشته نشود، زیرا قرار دادن آدرس‌های ایمیل شخصی در وبسایت‌ها می‌تواند یک بردار حمله بالقوه برای مهاجمان باشد.
- اگر ایمیل‌ها **خارج از ساعات کاری** ارسال شوند، ممکن است حمله‌کننده در **منطقه زمانی متفاوتی** زندگی کند. با جمع‌آوری چنین اطلاعاتی، می‌توانیم شروع به درک و معنا بخشیدن به حمله کنیم.

هدر ایمیل چیست و چگونه آن را بخوانیم؟

در این بخش، توضیح خواهیم داد که **اطلاعات هدر** در یک ایمیل چیست، با این اطلاعات چه کاری می‌توان انجام داد و چگونه می‌توان به این اطلاعات دسترسی پیدا کرد.

توجه: دنبال کردن دقیق این بخش مهم است، زیرا در بخش بعدی نحوه انجام **تحلیل هدر** را توضیح خواهیم داد.



هدر ایمیل چیست؟

"هدر" اساساً بخشی از نامه است که حاوی اطلاعاتی مانند فرستنده، گیرنده و تاریخ است. علاوه بر این، فیلدهایی مانند "مسیر بازگشت"، "پاسخ به" و "دریافت" وجود دارد. در زیر می توانید جزئیات هدر یک نمونه ایمیل را مشاهده کنید.

```
Delivered-To: info@letsdefend.io
Received: by 2002:ab4:8fc7:0:0:0:0 with SMTP id cs7csp1721687ecb;
Mon, 21 Mar 2022 06:10:11 -0700 (PDT)
X-Received: by 2002:a05:620a:2416:b0:6d:7735:4bbf with SMTP id d22-20020a05620a241600b0067d77354bbfmr12659013qkn.501.1647868211414;
Mon, 21 Mar 2022 06:10:11 -0700 (PDT)
ARC-Seal: i=1; a=rsa-sha256; t=1647868211; cv=none;
d=google.com; s=arc-20160816;
b=ZxH9+3UjmlxSK/Y/LeaLuupLgQT9gWm7l2agKamcTCU/4Tp5WlYpwX2e7PKv4gz30h
4jUc3QKlzm1t8KREmbs4RRQz8E7Varx+b2ZpejUitxWixYcoOWt25rWx1UnUU29vdT
OuGxWQYjJqfJLoQeaDRSPoaFWKBrLbgfluZv7R5A9sYjVgF9jE/JfY2HqBiHWvK/Z6v55
FH7TBavChCAdh7ronXI4FfxggfVgh7yEAKo6qHmTWA3CsuseMKh18P4M2ELNaMtx2t0
Ej5MiiM8BR/nJjetLwcuyNh37acMD7fuB4Atsu+4FS4sa8dFA9JSwR7wAUNTl4zn7bG
vlpq=
ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20160816;
h=mime-version:delivered-to:date:message-id:subject:to:from
dkim-signature;
bh=HIAfgOLdaK3JQLpH5fJuRxiVU9cb88FSU4V8M1V9sI=;
b=DQbcXx7CopYCaegIw+c82nMD8Tr6SGHNR4p+jqBAgtDIm3/TXsiJwKXJJv/Yj6HRp9
Ynm2RuORLLdaJchuk1cl7wngpFLP2678iuQs2vzPBfEMbgjRZbh/2OeIaNBpkEMzlaDo
4a6MNUz1/DJmLVQokQ7s5hYePucKTGhpziJQDC/7aubWiaXuOzWvNt9V2GsHOxvRh
dph2LsXWAdYDc6sAGctWR7wIve4zoDBw/evWoH/g55aChuX8KGB7OPuP3GL2fo0F296
EAVSovT/zvP10/MN6oaSOWIYoYshyKm36ceOtbFZLqDYhxs1D+NeXEk8seecPz14LgG
lNEg=
ARC-Authentication-Results: i=1; mx.google.com;
dkim=pass header.i=@letsdefend.io header.s=google header.b=hRMOgQ3u;
spf=pass (google.com: domain of ogunal@letsdefend.io designates 209.85.220.41 as permitted sender) smtp.mailfrom=ogunal@letsdefend.io
Return-Path: <ogunal@letsdefend.io>
Received: from mail-sor-f41.google.com (mail-sor-f41.google.com. [209.85.220.41])
by mx.google.com with SMTPS id d7-20020ac8544700000b002de980041b8sor9866778gtq.15.2022.03.21.06.10.11
for <info@letsdefend.io>
(Google Transport Security);
Mon, 21 Mar 2022 06:10:11 -0700 (PDT)
Received-SPF: pass (google.com: domain of ogunal@letsdefend.io designates 209.85.220.41 as permitted sender) client-ip=209.85.220.41;
Authentication-Results: mx.google.com;
dkim=pass header.i=@letsdefend.io header.s=google header.b=hRMOgQ3u;
spf=pass (google.com: domain of ogunal@letsdefend.io designates 209.85.220.41 as permitted sender) smtp.mailfrom=ogunal@letsdefend.io
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
d=letsdefend.io; s=google;
h=from:to:subject:message-id:date:delivered-to:mime-version;
bh=HIAfgOLdaK3JQLpH5fJuRxiVU9cb88FSU4V8M1V9sI=;
b=hRMOgQ3uKl9FSba7f/JlWB2QkC0Rr8IR6YgQBJlHTp9egr9Vwpc6qHPYHskxOdgT0
7wxxkHhKrBLJwGjqXeVv+MNBXK52fiLw3B3esnnMdrmyysJLuRuvyRV2LakLqY9gCc
1W0yOLWFT/990p5h4GQMJPSPYQLPb2TWJEWc2UdfCHte4YHuxB1PUVZ26lwhpbqNdxGy
jCkBB14DN0AM3o1u5tu6hVZr6kgreS7TTrShGz/73bTMOJnoExH/XU+V8RmYP60ei3Av
```

Email Header چه کاری انجام می دهد؟

TryHackBox

الف. شناسایی فرستنده و گیرنده را فعال می کند.

به لطف فیلدهای «from» و «to» در سربرگ، مشخص می شود که ایمیل از چه کسی به چه کسی ارسال می شود. اگر به ایمیل بالا که با فرمت "eml" دانلود کرده اید نگاه کنیم، می بینیم که از آدرس ارسال شده است

ogunal@letsdefend.io به info@letsdefend.io



ب. مسدود کننده هرزنامه

شناسایی ایمیل های اسپم با استفاده از تحلیل هدر و روش های مختلف دیگر امکان پذیر است. این کار افراد را از دریافت ایمیل های اسپم محافظت می کند.

ج. ردیابی مسیر ایمیل

مهم است که مسیری را که دنبال می کند بررسی کنید تا ببینید آیا ایمیلی از آدرس درست آمده است یا خیر. اگر به نمونه ایمیل بالا نگاه کنیم، می بینیم که از آدرس `ogunal@letsdefend.io` آمده است، اما آیا واقعاً از آن آمده است یا دامنه `letsdefend.io` از سرور جعلی دیگری که همان نام را تقلید می کند؟

Important Email Header Fields

فیلدهای مهم هدر ایمیل

From از

- این فیلد در هدر اینترنتی، نام و آدرس ایمیل فرستنده را نشان می دهد.

To به

- این فیلد در هدر ایمیل شامل اطلاعات دریافت کننده ایمیل است.
- این فیلد شامل نام و آدرس ایمیل آن ها می شود. فیلدهایی مانند CC (رونوشت) و BCC (رونوشت پنهان) نیز در این دسته قرار می گیرند زیرا همگی شامل اطلاعات دریافت کنندگان شما هستند.

Date تاریخ

- این یک مهر زمانی است که نشان می دهد ایمیل در چه زمانی ارسال شده است.
- در جیمیل، این فیلد معمولاً از فرمت زیر روز در هفته روز ماه سال ساعت:دقیقه:ثانیه `day dd month yyyy hh:mm:ss` پیروی می کند.



- به عنوان مثال، اگر ایمیلی در ۱۶ نوامبر ۲۰۲۱، ساعت ۴:۵۷:۲۳ بعدازظهر ارسال شده باشد، به این شکل نمایش داده می‌شود Wed, 16 Nov 2021 16:57:23

Subject موضوع

- موضوع ایمیل، عنوان یا مبحث ایمیل را ذکر می‌کند. این فیلد محتوای کل بدنه پیام را خلاصه می‌کند.

Return-Path مسیر بازگشت

- این فیلد هدر ایمیل که با نام **Reply-To** (پاسخ به) نیز شناخته می‌شود، مشخص می‌کند که پاسخ ایمیل به کدام آدرس ارسال خواهد شد.

DKIM Signatures&Domain Key

- **Domain Key** و **DKIM** امضاهای ایمیلی هستند که به ارائه‌دهندگان سرویس ایمیل کمک می‌کنند تا ایمیل‌های شما را شناسایی و احراز هویت کنند. عملکردی مشابه امضاهای SPF دارند.

Message-ID شناسه پیام

- فیلد هدر **Message-ID** یک ترکیب منحصر به فرد از حروف و اعداد است که هر ایمیل را شناسایی می‌کند. هیچ دو ایمیلی **Message-ID** یکسان ندارند.

MIME-Version

- یک استاندارد اینترنتی برای کدگذاری است. این استاندارد محتوای غیرمتنی مانند تصاویر، ویدیوها و سایر پیوست‌ها را به متن تبدیل می‌کند تا بتوان آن‌ها را از طریق پروتکل SMTP به ایمیل پیوست کرده و ارسال نمود.

Received دریافت شده

- فیلد **Received** هر سرور ایمیلی که ایمیل قبل از رسیدن به صندوق ورودی دریافت‌کننده از آن عبور کرده را فهرست می‌کند. این فهرست به ترتیب زمانی معکوس



مرتب شده است جایی که سرور ایمیل در بالای فهرست، آخرین سروری است که ایمیل از آن عبور کرده و سرور در پایین فهرست، مبدأ اصلی ایمیل است.

X-Spam Status وضعیت اسپم

- فیلد X-Spam Status نمره اسپم یک پیام ایمیل را نشان می‌دهد.
- در ابتدا مشخص می‌کند که آیا پیام به عنوان اسپم طبقه‌بندی شده است یا خیر.
- سپس نمره اسپم ایمیل و همچنین آستانه اسپم برای آن ایمیل نشان داده می‌شود.
- یک ایمیل می‌تواند یا به آستانه اسپم صندوق ورودی برسد یا از آن فراتر رود. اگر ایمیل بیش از حد اسپم باشد و از آستانه تعیین شده فراتر رود، به طور خودکار به عنوان اسپم طبقه‌بندی شده و به پوشه اسپم ارسال می‌شود.

چگونه به هدر ایمیل خود دسترسی پیدا کنیم؟

جیمیل

- 1- ایمیل مربوطه را باز کنید
- 2- روی 3 نقطه بالا سمت راست کلیک کنید "..."
- 3- بر روی دکمه «دانلود پیام» کلیک کنید.
- 4- دانلود شده ی فایل را با پسوند "eml" با هر برنامه نوت بوکی باز کنید





انواع آنالیز یک ایمیل مشکوک

تجزیه و تحلیل استاتیک

این یک واقعیت است که نامه هایی که از متن ساده تشکیل شده اند خسته کننده هستند. به همین دلیل، برنامه های پست الکترونیکی از HTML پشتیبانی می کنند که این امکان را فراهم می کند ایجاد ایمیل هایی که می توانند توجه بیشتر کاربران را به خود جلب کنند. البته این ویژگی یک نقطه ضعف دارد. مهاجمان می توانند ایمیل هایی با HTML ایجاد کنید، آدرس های URL مضر را در پشت دکمه ها/متون هایی که بی ضرر به نظر می رسند پنهان کنید.

Last day to take advantage of your special \$ 250 coupon! You can access your voucher via the address below.

<http://popularshoppingsite.com>

[https://maliciousaddress.com/
email=personal_email@gmail.com](https://maliciousaddress.com/email=personal_email@gmail.com)

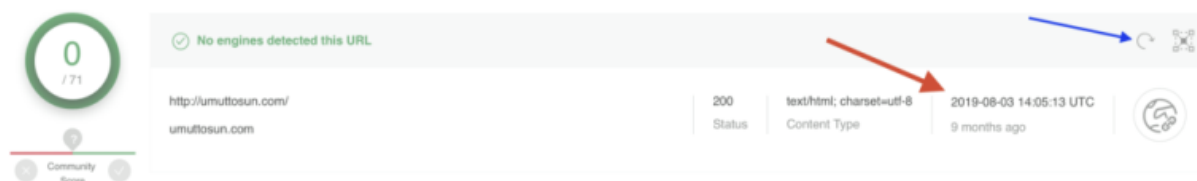
همانطور که در تصویر بالا مشاهده می شود، آدرسی که کاربر می بیند در هنگام کلیک کردن روی لینک می تواند متفاوت باشد (آدرس واقعی زمانی که لینک نشان داده می شود دیده می شود).

مهاجمان در اکثر حملات فیشینگ یک آدرس دامنه جدید می گیرند و در عرض چند روز یک حمله فیشینگ انجام می دهند و کار خود را تمام می کنند. به همین دلیل، اگر نام دامنه در نامه جدید باشد، احتمال حمله فیشینگ بیشتر است.

می توان با جستجوی آدرس های وب در ایمیل در VirusTotal متوجه شد که آیا موتورهای آنتی ویروس آدرس وب را مضر تشخیص می دهند یا خیر. اگر شخص دیگری قبلاً همان آدرس یا فایل را در VirusTotal تجزیه و تحلیل کرده باشد، VirusTotal از ابتدا تجزیه و تحلیل



نمی کند، نتیجه تجزیه و تحلیل قدیمی را به شما نشان می دهد. ما می توانیم از این ویژگی هم به عنوان یک مزیت و هم به عنوان یک نقطه ضعف استفاده کنیم.



اگر مهاجم آدرس دامنه را در VirusTotal بدون اینکه حاوی محتوای مضر در آن باشد جستجو کند، آن آدرس در VirusTotal بی ضرر به نظر می رسد و اگر مورد توجه قرار نگیرد، ممکن است اشتباه کنید که این آدرس بی ضرر است.

در تصویر بالا می بینید که آدرس umuttosun.com بی ضرر به نظر می رسد، اما اگر به قسمتی که با فلش قرمز مشخص شده است نگاه کنید، می بینید که این آدرس 9 ماه پیش جستجو شده است و این نتیجه مربوط به 9 ماه پیش است. برای تجزیه و تحلیل مجدد، دکمه مشخص شده با فلش آبی باید فشار داده شود. انجام تجزیه و تحلیل استاتیک فایل های موجود در نامه می تواند یادگیری ظرفیت / قابلیت های آن فایل را امکان پذیر کند. با این حال، از آنجایی که تجزیه و تحلیل استاتیک زمان زیادی می برد، با تجزیه و تحلیل پویا می توانید اطلاعات مورد نیاز خود را سریعتر به دست آورید.

Cisco Talos Intelligence دارای بخش های جستجو است که می توانیم شهرت آدرس های IP را یاد بگیریم. با جستجوی آدرس SMTP نامه ای که در Talos شناسایی کرده ایم، می توانیم شهرت آدرس IP را ببینیم و متوجه شویم که آیا در لیست سیاه قرار دارد یا خیر. اگر آدرس SMTP در لیست سیاه باشد، می توان فهمید که یک حمله انجام شده است.



LOCATION DATA	REPUTATION DETAILS
Seychelles	EMAIL REPUTATION Poor
OWNER DETAILS	WEB REPUTATION (New Legacy) Questionable Neutral
IP ADDRESS 185.10.68.76	LAST DAY LAST MONTH
FWD/REV DNS MATCH Yes	SPAM LEVEL None None
HOSTNAME 76.68.10.185.ro.ov0.sc	EMAIL VOLUME 0.0 0.0
DOMAIN ov0.sc	VOLUME CHANGE 0%
NETWORK OWNER Flooknet Ltd	Think these reputation details are incorrect? Submit a dispute here
CONTENT DETAILS	BLACKLISTS
CONTENT CATEGORY No established content categories	BL.SPAMCOP.NET Not Listed
Think these category details are incorrect? Submit a dispute here	CBL.ABUSEAT.ORG Not Listed
	PBL.SPAMHAUS.ORG Not Listed
	SBL.SPAMHAUS.ORG Not Listed
	TALOS SECURITY INTELLIGENCE BLACKLIST
	BLACKLISTED Yes

به همین ترتیب، آدرس SMTP را می توان در VirusTotal و AbuseIPDB جستجو کرد تا مشخص شود آیا آدرس IP قبلاً در فعالیت های مخرب دخیل بوده است یا خیر.

تجزیه و تحلیل دینامیک

آدرس ها و فایل ها را می توان در ایمیل پیدا کرد. این فایل ها و آدرس های URL باید بررسی شوند. شما داده های خود را نمی خواهید

با اجرای این فایل ها بر روی کامپیوتر شخصی شما توسط هکرها به سرقت رفته است. به همین دلیل وب سایت ها و فایل های موجود در

mail باید در محیط های sandbox اجرا شود و تغییرات ایجاد شده در سیستم بررسی شود و مضر بودن یا نبودن آنها را بررسی کرد.

browserling

Features | Pricing | Live API | About Us | Sign In | [Sign Up](#)

Live interactive cross-browser testing

[Test now!](#)

Windows 7 Chrome 75

Get a browser and start testing in 5 seconds!



بررسی امن لینک‌ها

اگر می‌خواهید به سرعت آدرس‌های وب موجود در ایمیل را بررسی کنید، می‌توانید محتوای وب‌سایت را با استفاده از مرورگرهای آنلاینی مانند **Browserling** مشاهده کنید. مزیت این سرویس‌ها این است که از آنجایی که شما به صورت مستقیم و روی کامپیوتر شخصی خود به صفحه وب مراجعه نمی‌کنید، تحت تأثیر یک آسیب‌پذیری روز صفر احتمالی که مرورگرها را تحت تأثیر قرار می‌دهد، قرار نخواهید گرفت.

عیب استفاده از مرورگرهای آنلاین مانند **Browserling** اگر فایل مخرب در سایت دانلود شود، شما نمی‌توانید این فایل را اجرا کنید. به همین دلیل، تحلیل شما ناتمام خواهد ماند.

محیط سندباکس برای تحلیل هدر ایمیل

شما می‌توانید فایل‌ها و وب‌سایت‌های مشکوک را در **محیط‌های سندباکس** بررسی کنید. هنگامی که فایل‌ها را در این محیط‌ها تحلیل می‌کنید، خطر آلوده شدن کامپیوتر خود به بدافزار را از بین می‌برید. بسیاری از سرویس‌ها/محصولات سندباکس به صورت رایگان و پولی در دسترس هستند. شما می‌توانید با توجه به نیازهای خود یک یا چند مورد از این سرویس‌ها را انتخاب کنید.

چند سندباکس پرکاربرد:

TryHackBox

- VMRay
- Cuckoo Sandbox
- JoeSandbox
- AnyRun
- Hybrid Analysis (Falcon Sandbox)



تذکر مهم (NOTE)

- بدافزار می تواند برای ایجاد تشخیص سخت تر، مدتی بدون هیچ فعالیتی در حالت انتظار بماند. شما باید قبل از اینکه تصمیم بگیرید فایل بررسی شده بی ضرر است، صبر کنید تا بدافزار فعالیت خود را آغاز کند.

- عدم وجود لینک و فایل در ایمیل به این معنی نیست که این ایمیل بی خطر است. مهاجم می تواند محتوای مخرب را به صورت یک تصویر نیز ارسال کند تا توسط محصولات تحلیلگر شناسایی نشود.

تکنیک های اضافی مهاجمان

تکنیک دیگری که مهاجمان استفاده می کنند، انجام حملات فیشینگ با استفاده از سایت های معمولاً قانونی است. برخی از این روش ها به شرح زیر است:

A. استفاده از سرویس های ذخیره سازی ابری مانند گوگل و مایکروسافت مهاجمان با آپلود فایل های مخرب روی فضای ابری (مانند Google Drive یا Microsoft Drive، سعی می کنند کاربر را به کلیک روی آدرس هایی که بی خطر به نظر می رسند، ترغیب کنند.

B. استفاده از سرویس هایی که ایجاد زیردامنه رایگان را مجاز می کنند (مانند مایکروسافت، وردپرس، بلاگ اسپات، ویکس)

مهاجمان با ایجاد یک زیردامنه رایگان از این سرویس ها سعی در فریب محصولات امنیتی و تحلیلگران دارند. از آنجایی که اطلاعات Whois برای زیردامنه ها قابل جستجو نیست، اینطور به نظر می رسد که این آدرس ها در گذشته ثبت شده و متعلق به مؤسساتی مانند مایکروسافت یا وردپرس است.



C. استفاده از برنامه‌های سازنده فرم (Form Applications)

سرویس‌هایی که امکان ایجاد رایگان فرم را فراهم می‌کنند، در دسترس هستند. مهاجمان به جای ایجاد یک سایت فیشینگ اختصاصی، از این سرویس‌ها استفاده می‌کنند. از آنجایی که دامنه این سرویس‌ها در شرایط عادی بی‌خطر است، می‌تواند بدون گیر کردن در نرم‌افزارهای آنتی‌ویروس به دست کاربر برسد **Google Form**. نمونه‌ای از این سرویس‌ها است. هنگام بررسی اطلاعات **Whois**، دامنه متعلق به گوگل دیده می‌شود، بنابراین مهاجم می‌تواند تحلیلگران را گمراه کند.

اقدامات دفاعی و محافظتی

برخی از لایه‌های دفاعی که برای کمک به پیشگیری از حملات فیشینگ ایمیل و سرقت اعتبارنامه‌ها باید در نظر گرفته شوند عبارتند از:

- اسکن و فیلتر کردن ایمیل‌ها
- درگاه‌های امنیتی ایمیل
- احراز هویت **DNS DMARC, DKIM**
- نرم‌افزارهای ضد بدافزار و ضد هرزنامه
- احراز هویت چندعاملی
- آگاهی بخشی امنیتی در مورد فیشینگ



مهندسی اجتماعی

Social Engineering Red Flags



FROM

- I don't recognize the sender's email address as someone I **ordinarily** communicate with.
- This email is from **someone outside my organization** and **it's not related to my job responsibilities**.
- This email was sent from **someone inside the organization** or from a customer, vendor, or partner and is **very unusual** or **out of character**.
- Is the sender's email address from a **suspicious domain** (like micorsoft-support.com)?
- I **don't know the sender personally** and they were **not vouched for** by someone I trust.
- I **don't have a business relationship** nor any past communications with the sender.
- This is an **unexpected or unusual email** with an **embedded hyperlink** or an **attachment** from someone I haven't communicated with recently.



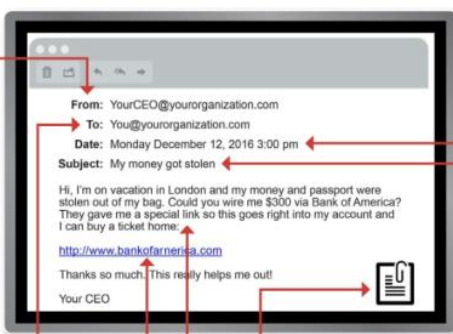
TO

- I was cc'd on an email sent to one or more people, but I **don't personally know** the other people it was sent to.
- I received an email that was also sent to an **unusual mix of people**. For instance, it might be sent to a random group of people at my organization whose last names start with the same letter, or a whole list of unrelated addresses.



HYPERLINKS

- I hover my mouse over a hyperlink that's displayed in the email message, but the **link-to address is for a different website**. (This is a **big red flag**.)
- I received an email that only has **long hyperlinks with no further information**, and the rest of the email is completely blank.
- I received an email with a **hyperlink that is a misspelling** of a known web site. For instance, www.bankofamerica.com — the "m" is really two characters — "r" and "n."



DATE

- Did I receive an email that I normally would get during regular business hours, but it was **sent at an unusual time** like 3 a.m.?



SUBJECT

- Did I get an email with a subject line that is **irrelevant** or **does not match** the message content?
- Is the email message a reply to something I **never sent or requested**?



ATTACHMENTS

- The sender included an email attachment that I **was not expecting** or that **makes no sense** in relation to the email message. (This sender doesn't ordinarily send me this type of attachment.)
- I see an attachment with a possibly **dangerous file type**. The only file type that is **always safe to click on** is a .txt file.



CONTENT

- Is the sender asking me to click on a link or open an attachment to **avoid a negative consequence** or to **gain something of value**?
- Is the email **out of the ordinary**, or does it have **bad grammar** or **spelling errors**?
- Is the sender asking me to click a link or open up an attachment that **seems odd** or **illogical**?
- Do I have an **uncomfortable gut feeling** about the sender's request to open an attachment or click a link?
- Is the email asking me to look at a **compromising or embarrassing picture** of myself or someone I know?

مهندسی اجتماعی (راهنمای شناسایی ایمیل فیشینگ)

برای تشخیص ایمیل‌های فیشینگ، این موارد را در بخش‌های مختلف ایمیل بررسی کنید:

فرستنده (FROM)

TryHackBox

- آدرس ایمیل فرستنده را به طور معمول نمی‌شناسم و با او ارتباطی ندارم.
- این ایمیل از شخصی خارج از سازمانم است و ربطی به وظایف شغلی من ندارد.
- این ایمیل از شخصی داخل سازمان یا از یک مشتری، فروشنده یا شریک ارسال شده اما بسیار غیرعادی یا خارج از رفتار معمول اوست.
- آیا آدرس ایمیل فرستنده از یک دامنه مشکوک است

مثل microsoft-support.com



- فرستنده را شخصاً نمی‌شناسم و فرد مورد اعتمادی نیز او را تأیید نکرده است.
- با فرستنده هیچ رابطه کسب و کاری یا سابقه مکاتبه ندارم.
- این یک ایمیل غم‌نیافته یا غیرمعمول حاوی یک لینک یا پیوست از کسی است که اخیراً با او ارتباطی نداشته‌ام.

گیرنده (TO)

- به عنوان CC در ایمیلی که به یک یا چند نفر ارسال شده قرار گرفته‌ام، اما بقیه دریافت‌کنندگان را شخصاً نمی‌شناسم.
- ایمیلی دریافت کرده‌ام که به ترکیب غیرمعمولی از افراد نیز ارسال شده است (مثلاً به گروهی تصادفی از افراد در سازمانم که نام خانوادگی آن‌ها با یک حرف شروع می‌شود، یا یک لیست طولانی از آدرس‌های نامربوط).

لینک‌ها (HYPERLINKS)

- وقتی ماوس را روی لینک موجود در ایمیل می‌برم، آدرسی که نمایش داده می‌شود مربوط به یک وبسایت کاملاً متفاوت است. این یک علامت خطر بزرگ است.
- ایمیلی دریافت کرده‌ام که فقط حاوی لینک‌های طولانی بدون هیچ اطلاعات دیگری است و بقیه ایمیل کاملاً خالی است.
- ایمیلی دریافت کرده‌ام که حاوی لینکی با املای غلط از یک وبسایت معروف است. به عنوان مثال www.bankofamerica.com که در آن حرف "m" در واقع از دو حرف "r" و "n" تشکیل شده است.



مثال عینی :

```
از: YourCEO@yourorganization.com
به: You@yourorganization.com
تاریخ: دوشنبه ۱۲ دسامبر ۲۰۱۶ ساعت ۳:۰۰ بعدازظهر
موضوع: پولم دزدیده شد

سلام، من در لندن در تعطیلات هستم و پول و پاسپورتم از کیفم دزدیده شده. می‌توانی ۳۰۰ دلار از طریق با
نک آمریکا برایم واریز کنی؟ آنها یک لینک ویژه به من داده‌اند تا پول مستقیماً به حسابم برود و بتو
انم بلیت برگشت بخرم.

http://www.bankofamerica.com

!خیلی ممنون! این واقعاً به من کمک می‌کند
مدیرعامل شما
```

تاریخ (DATE)

- آیا ایمیلی که معمولاً در ساعات کاری عادی دریافت می‌کنم، این بار در ساعت غیرمعمولی (مثل ۳ نیمه شب) ارسال شده است؟

موضوع (SUBJECT)

- آیا ایمیلی با خط موضوعی نامربوط دریافت کرده‌ام که با محتوای پیام همخوانی ندارد؟
- آیا این ایمیل، پاسخی است به چیزی که من هرگز آن را ارسال یا درخواست نکرده‌ام؟

پیوست‌ها (ATTACHMENTS)

- فرستنده یک پیوست دارد که منتظرش نبوده‌ام یا در رابطه با متن ایمیل بی‌معنا است. (این فرستنده معمولاً چنین نوع پیوستی برایم نمی‌فرستد).
- پیوستی با پسوند فایل بالقوه خطرناک مشاهده می‌کنم. تنها پسوند فایلی که همیشه ایمن است، **txt** است.



محتوا (CONTENT)

- آیا فرستنده از من می‌خواهد برای اجتناب از یک عاقبت منفی یا به دست آوردن چیزی با ارزش روی لینکی کلیک کنم یا پیوستی را باز کنم؟
- آیا ایمیل غیرعادی است یا حاوی اشتباهات دستوری و املایی است؟
- آیا فرستنده از من می‌خواهد که یک لینک «عجیب» یا «غیرمنطقی» را باز کنم؟
- آیا درباره درخواست فرستنده برای باز کردن پیوست یا کلیک روی لینک، یک حس ناخوشایند درونی دارم؟
- آیا ایمیل از من می‌خواهد به عکس **compromis** کننده یا خجالت‌آوری از خودم یا کسی که می‌شناسم نگاه کنم؟

